КРИПТОГРАФИЯ И ПРОТОКОЛЫ БЕЗОПАСНОСТИ

Пестунов Андрей Игоревич
канд. физ.-мат. наук, доцент
andrey.pestunov@yandex.ru

ТЕМА 1. ИНСТРУМЕНТАРИЙ КРИПТОГРАФИИ И ЕЕ МЕСТО В ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

ТЕРМИН КРИПТОГРАФИЯ ПОЯВИЛСЯ РАНЬШЕ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

На начальном этапе криптография = шифрование

Зашифрование – преобразование информации к **бессмысленному** виду

Расшифрование – восстановление **исходного** вида информации из бессмысленного после зашифрования

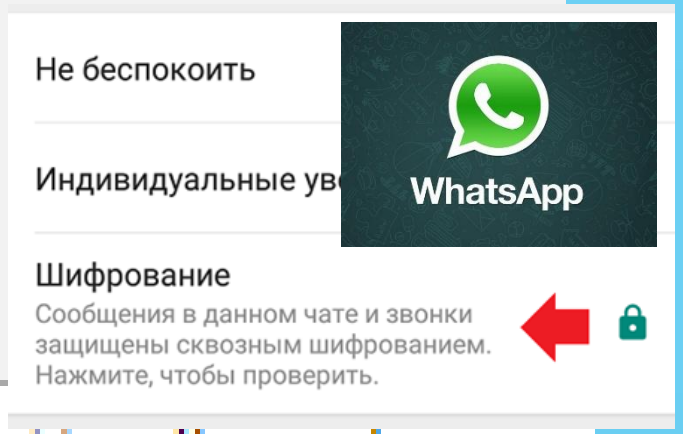
- **Криптография** – область исследований, направленных на разработку методов защиты информации посредством ее **преобразования** к такому виду, чтобы осуществить **непредписанные** действия было невозможно
- **Криптоанализ** – исследование **стойкости** криптосистемы. Часто осуществляется через моделирование **атак**

Криптология = криптография + криптоанализ

ПОЧЕМУ ИМЕННО В XX И XXI ВЕКАХ НАБЛЮДАЕТСЯ СТРЕМИТЕЛЬНОЕ РАЗВИТИЕ ПРОТОКОЛОВ БЕЗОПАСНОСТИ?

Появилась масса **дешевых и легкодоступных** средств обработки, передачи и генерации данных информации.

- Мобильный телефон, смартфон
- Интернет
- Беспроводной интернет
- Корпоративные сети
- Облачные технологии



https://mail.yandex.ru

Вследствие этого многие процессы из физического мира **переносятся в компьютерную сетевую среду**.

Регулировать и осуществлять их защиту только физическими, законодательными и другими **традиционными средствами неэффективно**.

Появляются **новые вызовы**

ПРИМЕР ТРАНСФОРМАЦИИ ЗАДАЧИ КОНФИДЕНЦИАЛЬНОЙ ПЕРЕДАЧИ ДАННЫХ

Один адресат

Обычное шифрование

Широковещание

Получить должны только адресаты, оплатившие подписку

Как трансформировать схему использования шифров, чтобы решить эту задачу?

ПРИМЕРЫ ПРОЦЕССОВ, ПЕРЕНЕСЕННЫХ В ВИРТУАЛЬНУЮ СРЕДУ

- **Коммуникации**
  - Вместо почты, личного общения, телефонных переговоров часто используются коммуникации посредством электронной почты, средств обмена мгновенными сообщениями, социальных сетей
- **Документооборот**
  - Вместо бумажного документооборота используются CRM-системы и другие средства автоматизации этого процесса
- **Игровые мероприятия**
  - Шахматы, карточные игры, интеллектуальные игры
- **Биржи**
  - Для торговли ценными бумагами, валютами и другими активами теперь часто не требуется физического присутствия, а достаточно осуществлять эту деятельность через специальные порталы
- **Торговля и финансы**
  - Интернет-магазины, онлайн-банки

ПРОБЛЕМЫ, КОТОРЫЕ ВОЗНИКАЮТ ПРИ ХРАНЕНИИ И ПЕРЕДАЧЕ ДАННЫХ

Данные между Алисой и Бобом передаются по так называемому **открытому каналу** связи, который может быть доступен Еве.

Поэтому Ева может:

- Прочитать секретные данные;
- Подменить данные;
- Испортить данные;
- Удалить данные;
- Выдать себя за законного пользователя;
- Получить средства законного пользователя;
- И т.д.

Усложняется модель нарушителя. Например, законный участник интерактивной игры может пытаться жульничать.

МЕСТО КРИПТОГРАФИИ В ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Информационная безопасность – состояние, при котором информация обладает свойствами **доступности**, **конфиденциальности** и **целостности**

Доступность

Пользователи реализуют **предписанные** им права доступа **беспрепятственно**

Конфиденциальность

С информацией могут ознакомиться **только** те пользователи, кому это **разрешено**

Целостность

Информация модифицируется **только** согласно установленным **правилам**

Защита информации – **комплексная деятельность** по обеспечению информационной безопасности

Криптографические методы защиты информации являются подмножеством всех методов **защиты информации**

ЗАЩИТА ИНФОРМАЦИИ КАК КОМПЛЕКСНАЯ ДЕЯТЕЛЬНОСТЬ ПО ОБЕСПЕЧЕНИЮ ИБ

Криптографические

Инженерно-технические

Программные

Физические

Методы защиты информации

Аппаратные

Организационные

Нормативно-правовые

КРИПТОГРАФИЧЕСКИЕ МЕТОДЫ ЗАЩИТЫ ИНФОРМАЦИИ

- Разработка и эксплуатация **криптографических методов** – это часть деятельности по обеспечению **информационной безопасности**
- К криптографическим методам относятся:
  - Методы **шифрования**
  - Цифровые **подписи**
  - Алгоритмы **распределения** секретных ключей
  - Криптографические **хеш-функции**
  - Иногда к криптографии относят **стеганографию**
  - Криптографические **протоколы**
  - …

Доступность

Целостность

Конфиденциальность

Инструмент криптографических методов – это **преобразование** информации к бессмысленному виду

КРИПТОГРАФИЯ НЕ ЗАНИМАЕТСЯ ОБЕСПЕЧЕНИЕМ ДОСТУПНОСТИ

- Криптографические методы **затрудняют доступ** к информации **всем** пользователям
- **Доступность** информации **ухудшается**

Задача криптографических методов

Законным пользователям снизить доступность **незначительно**

Незаконным пользователям затруднить доступ настолько, **чтобы они не смогли преодолеть это препятствие на практике**

Оговорка. Доступность затрудняется **не столько к данным**, сколько к информации, т.е. к их **смысловой интерпретации**

Законность рассматривается в привязке к **контексту** (информация + действие)

СТРАТЕГИЯ СОВРЕМЕННОЙ КРИПТОГРАФИИ

Законные пользователи: обладают **секретным ключом**, который позволяет им выполнять некоторые преобразования **«быстро»**

Незаконные пользователи: могут выполнить эти преобразования («взломать» защиту) с использованием настолько больших ресурсов («астрономических»), что **получить их на практике нереально**

Незаконные пользователи: могут «взломать» систему **с ничтожно малой вероятностью**. Например, взять наугад секретный ключ, и он окажется верным

Какие операции?

- Зашифрование
- Расшифрование
- Подписание
- Генерация нужного числа
- Аутентификация

Для незаконного:

- Узнать секрет
- Узнать ключ

Упрощенно (с оговорками):

Законные пользователи используют **полиномиальные алгоритмы**

Незаконные пользователи могут «взломать» только за **экспоненциальное время**

ПАРАМЕТР БЕЗОПАСНОСТИ И ПОЛНЫЙ ПЕРЕБОР

Параметр безопасности криптосистемы – это длина ключа (возможно другой) криптосистемы, которая **не имеет методов «взлома» эффективнее полного перебора** и обеспечивает тот же уровень безопасности, что и эта криптосистема

Если криптосистема может быть «взломана» только полным перебором, то ее **параметр безопасности равен длине ключа**

- Применяемые криптографические методы **не имеют полиномиальных методов их «взлома»** в общем случае
- Даже при совершенствовании методов «взлома» **всегда можно увеличить параметры** криптографического метода (ключ или иные параметры), чтобы **сохранить уровень безопасности** на прежнем уровне

НЕ ДЛЯ ВСЕХ АЛГОРИТМОВ ПОЛНЫЙ ПЕРЕБОР НАИБОЛЕЕ ЭФФЕКТИВЕН

Если **известны более эффективные методы** «взлома», то **ключ** (и иные параметры) **должен быть длиннее**

Date	Security Strength	Symmetric Algorithms	Factoring Modulus	Discrete Logarithm Key	Discrete Logarithm Group	Elliptic Curve	Hash (A)	Hash (B)
Legacy (1)	80	2TDEA	1024	160	1024	160	SHA-1 (2)	
2019 - 2030	112	(3TDEA) (3) AES-128	2048	224	2048	224	SHA-224 SHA-512/224 SHA3-224	
2019 - 2030 & beyond	128	AES-128	3072	256	3072	256	SHA-256 SHA-512/256 SHA3-256	SHA-1 KMAC128
2019 - 2030 & beyond	192	AES-192	7680	384	7680	384	SHA-384 SHA3-384	SHA-224 SHA-512/224 SHA3-224
2019 - 2030 & beyond	256	AES-256	15360	512	15360	512	SHA-512 SHA3-512	SHA-256 SHA-512/256 SHA-384 SHA-512 SHA3-256 SHA3-384 SHA3-512 KMAC256

KEYLENGTH.COM

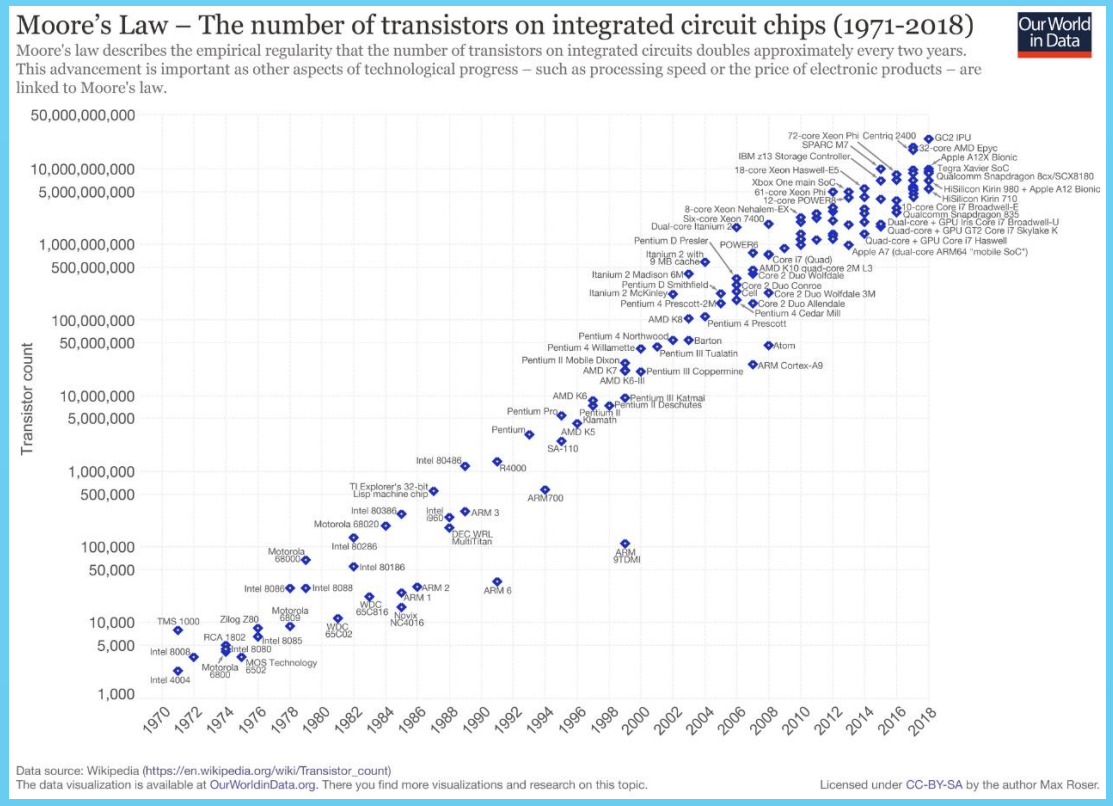
КАК ВЛИЯЕТ ЗАКОН МУРА НА СТОЙКОСТЬ КРИПТОСИСТЕМ?

Закон Мура

Число транзисторов, которые технологически возможно разместить на кристалле микросхемы схемы **удваивается каждые два года**

Следствие

Приблизительно с такой же скоростью **растут вычислительные мощности**



Следствие. Возможности злоумышленника удваиваются каждые два года

КАК РАЗРАБОТЧИКИ КРИПТОСИСТЕМ ДОЛЖНЫ РЕАГИРОВАТЬ НА ЗАКОН МУРА?

- В 2004 году (см. Б. Шнайер) условная граница стойкости находилась в районе **80 бит** (10 символов).
- За прошедшие с 2004 до 2024 года 20 лет мощности злоумышленника **выросли в 1024 раза** (удвоились 10 раз).
- Значит, в 2024 году в качестве условной границы для стойкости можно принять **90 бит**

Нужно сделать так, чтобы вычислительная **сложность «взлома» росла** с такой же скоростью

Добиться этого можно за счет **увеличения длины ключа**

КАКОВ ЗАПАС ДЛИНЫ КЛЮЧА?

На какой срок хватит ключей длиной 128 и 256 бит с учетом закона Мура?

- Выполним оценку времени, в течение которого длина ключей современных шифров останется достаточной.
- **<u>Шифр с длиной ключа 128 бит</u>**
  - Сколько раз требуется удвоить мощность злоумышленника? 128 – 90 = **40**
  - 40 * 2 = **80 лет**
- **<u>Шифр с длиной ключа 256 бит</u>**
  - Сколько раз требуется удвоить мощность злоумышленника? 256 – 90 = **168**
  - 168 * 2 = **336 лет**

СРАВНЕНИЕ ДЛИН КЛЮЧА ШИФРОВ

ГРАНИЦА БЕЗОПАСНОСТИ – 88 БИТ

Название шифра	Длина ключа		Количество всех возможных ключей
	в битах	в символах (байтах)	
Шифр Цезаря (русский алфавит)	5	0,625	32
DES	56	7	10^{16}
Skipjack	80	10	10^{24}
AES (мин.), CAMELLIA (мин.)	128	16	10^{38}
3DES	168	21	10^{51}
AES (макс.), CAMELLIA (макс.), ГОСТ 28147-89, ГОСТ Р 34.12-2015	256	32	10^{77}

КРИПТОГРАФИЯ АКТУАЛЬНА В ПРЕДПОЛОЖЕНИИ, ЧТО P≠NP

Основа криптографии – односторонние функции

Возведение в степень по модулю

$y = f(x) = a^x \bmod p$

М-кратная композиция

$q = f(m) = [m]p$

Умножение от 2-х аргументов

$y = f(P, Q) = P*Q$

Шифр

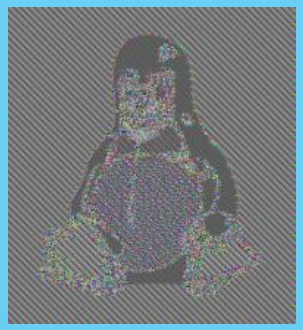
y = f(текст, ключ)

Односторонние функции ∃ => P≠NP

КРИПТОГРАФИЧЕСКИЕ ПРИМИТИВЫ И ПРОТОКОЛЫ

Криптографические примитивы – (относительно) низкоуровневые алгоритмы, с четко определенными **интерфейсами** и **свойствами**; в чистом виде их функционал очень ограничен

Блочный шифр в базовом режиме (ECB)



Пример.
Итеративный блочный шифр – **примитив**
Режим использования шифра - **протокол**

Криптографические протоколы – алгоритмы, схемы и механизмы использования и комбинирования криптографических **примитивов** для решения конкретных **практических задач** (функций криптосистемы)

КРИПТОАНАЛИЗ – ОЦЕНКА СТОЙКОСТИ ПРИМИТИВОВ И ПРОТОКОЛОВ

Анализ криптографический (криптоанализ) – исследование системы криптографической с целью получения обоснованных оценок ее стойкости криптографической

Уязвимости на примере шифра Цезаря

- **Малое количество возможных ключей**
  - Шифр уязвим для метода полного перебора ключей
  - Достаточно осуществить пробные расшифрования для всех возможных ключей
- **Плохие перемешивающие свойства**
  - Шифр уязвим к атаке частотным анализом.
  - **МОЛОКО -> НПМПЛП**

МОДЕЛИРОВАНИЕ АТАК – ОДИН ИХ ОСНОВНЫХ ПОДХОДОВ К КРИПТОАНАЛИЗУ

Атака на криптосистему – попытка злоумышленника понизить уровень безопасности конкретной криптосистемы.

- Совокупность различных атак расширяется за счет развития теоретических методов и возможностей техники.

Для криптографии **атака** – **алгоритм**, позволяющий показать, что криптосистема ведет себя **не так, как заявлено**.

- вычислить секретный ключ **быстрее**, чем полный перебор ключей
- обосновать, что шифрованные текст **неслучаен**
- показать, что есть **слабые ключи** (для них уровень безопасности ниже)
- найти уязвимости у **упрощенной** версии криптосистемы
- найти коллизии (для криптографической хеш-функции)
- эффективно выполнить **действие**, доступное только обладателю секретного ключа

В русскоязычной научной лит-ре термин **«взломать»** используется неохотно

ПРИНЦИП КЕРХГОФФСА (УЧИТЫВАЕТСЯ ПРИ РАЗРАБОТКЕ КРИПТОГРАФИЧЕСКИХ СИСТЕМ)

Принцип. *Предполагается, что злоумышленник знает о криптосистеме (протоколе) все, кроме секретного ключа.*

- **Главная идея.** Алгоритм шифрования (цифровой подписи, протокола аутентификации и пр.) считается известным злоумышленнику.
- Криптоалгоритм **в секрете не держится**.
- Одно из **воплощений** данного принципа – это государственные **стандарты** на криптоалгоритмы.
- Стандарты дают **полную спецификацию алгоритмов**, поэтому говорить о неизвестности алгоритма просто бессмысленно.

Исходная формулировка: «Компрометация системы не должна причинять неудобств корреспондентам»

ОБНОВЛЕНИЕ ОТЕЧЕСТВЕННЫХ СТАНДАРТОВ

Название алгоритма	Тип алгоритма	Введен в действие
ГОСТ 28147-89 (Магма)	Итеративный блочный шифр	1989
ГОСТ Р 34.12-2015 (Кузнечик)	Итеративный блочный шифр	2015
ГОСТ Р 34.12-2018 (Кузнечик) – Межд.	Итеративный блочный шифр	2019
ГОСТ Р 34.11-94	Криптографическая хеш-функция	1994
ГОСТ Р 34.11-2012 (Стрибог)	Криптографическая хеш-функция	2012
ГОСТ Р 34.11-2018 (Стрибог) – Межд.	Криптографическая хеш-функция	2019
ГОСТ Р 34.10-94	Цифровая подпись	1995
ГОСТ Р 34.310-95 – Межд.	Цифровая подпись	1998
ГОСТ Р 34.10-2001	Цифровая подпись	2001
ГОСТ Р 34.310.2004 – Межд.	Цифровая подпись	2004
ГОСТ Р 34.10-2012	Цифровая подпись	2013
ГОСТ 34.10-2018 – Межд.	Цифровая подпись	2019

ГОСУДАРСТВЕННЫЕ СТАНДАРТЫ НА КРИПТОГРАФИЧЕСКИЕ ПРИМИТИВЫ

Название стандарта	Тип алгоритма	Год
ГОСТ 28147-89 (Магма)	Блочный шифр	1989
ГОСТ Р 34.12-2015 (Кузнечик)	Блочный шифр	2015
Advanced Encryption Standard (Rijndael)	Блочный шифр	2001
Data Encryption Standard (DES)	Блочный шифр	1977
Camellia (Япония)	Блочный шифр	2003
SM4 (Китай)	Блочный шифр	2012
ГОСТ Р 34.11-94	Хеш-функция	1994
ГОСТ Р 34.11-2012 «Стрибог»	Хеш-функция	2012
SHA-2	Хеш-функция	2002
SHA-3	Хеш-функция	2015
ГОСТ Р 34.10-2012	Цифровая подпись	2012
ГОСТ 34.10-94	Цифровая подпись	1994
DSA	Цифровая подпись	1994
ECDSA	Цифровая подпись	2000

СЕРТИФИКАЦИЯ И БИБЛИОТЕКИ

Существует **система сертификации** средств защиты данных государственными органами: ФСБ и ФСТЭК

Библиотека	Язык программирования
Crypto++® Library	**C++**
phpCrypt – A PHP Encryption Library	**PHP**
Javax.crypto	**Java**
System.Security.Cryptography	**C#**
Stanford Javascript Crypto Library (SJCL)	**Javascript**
PyCrypto	**Python**

ПОЧЕМУ УДОБНО ИСПОЛЬЗОВАТЬ ПРИНЦИП КЕРХГОФФСА?

- Разглашение криптоалгоритма не приводит к необходимости его замены, **достаточно заменить только ключ**;
- **Ключи можно хранить отдельно от криптоалгоритма** и загружать их в криптосистему по мере необходимости;
- Не требуется хранить в секрете **сложный алгоритм**;
- Открытый криптоалгоритм **может быть исследован большим количеством ученых**, а не только теми лицами, которым он известен.
- Известный алгоритм может быть **публично стандартизован**.
- Может быть реализовано **серийное производство** программного обеспечения и аппаратных средств, реализующих открытые криптоалгоритмы.

СЦЕНАРИИ АТАК В РАМКАХ ПРИНЦИПА КЕРХГОФФСА?

- **По шифрованному тексту –** *только шифровка*
  - Ciphertext-only attack
- **По известному открытому тексту –** *кусок открытых данных*
  - Known-plaintext attack
- **По выбранному открытому тексту –** *шифрует, что угодно*
  - Chosen-plaintext attack
- **На связанные ключи –** *несколько связанных ключей*
  - Related-key attack

ВОПРОСЫ ДЛЯ САМОКОНТРОЛЯ

1. Какова связь между понятиями **криптология**, **криптография** и **криптоанализ**?
2. Перечислите основные криптографические **примитивы**.
3. В чем разница между криптографическими **примитивами** и **протоколами**?
4. Что такое **параметр безопасности**?
5. Какова связь **гипотезы P≠NP** и криптографии?
6. Объясните **понятие односторонней функции** и приведите примеры.
7. Как должен учитываться **закон Мура** при разработке криптосистем?
8. В чем заключается **принцип Керхгоффса** и мотивация его использования?
9. Какие основные **сценарии атак** на криптосистемы рассматриваются в рамках принципа Керхгоффса?

Спасибо за внимание!